WATTLEBRIDGE COMMUNITY SERVICES

Cyber Clinic Portfolio

Executive Pre-Meeting Briefing

CSE2HUM Human Factors in Cybersecurity | Assessment 3 | Part A

Advisory team / group	A3 GROUP 38
Team members	Seth Davies-Patrick, Javier Diaz-Aliste, Eddie Gosden
Student IDs	[redacted], [redacted], [redacted]
Date submitted	12/10/26
Prepared for	WattleBridge Executive Leadership Team

1. Executive overview

Our main finding is that WattleBridge doesn't have an awareness problem. Most of the staff already know what to do. 68% know where to report something suspicious and training completion sits at 89%. But only 39% actually reported the last suspicious item through a formal channel (E1). The problem sits where work is mobile, client-facing and hard to oversee.

We recommend focusing on these three risks over the next 12 months.

1. Frontline staff

They are the biggest group, and they score the lowest on how well security fits their work. They're also the least comfortable admitting mistakes and the least likely to report a phishing email.

2. The reporting gap

People know how to report but often don't. The current procedure was written for safeguarding, guidance is hard to find, and admitting a mistake doesn't feel safe.

3. Volunteer and guest accounts

These aren’t always switched off when people leave. An ex-volunteer’s account stayed active for 19 days in August 2026, and the access review found the same issue in other accounts.

These risks come mostly from conditions rather than from individuals. Conditions such as unreliable connectivity on outreach visits, managers giving different messages, policies written before outreach work was common, and no one clearly owning volunteer offboarding.

Our plan fixes those conditions before adding any new training. It rewrites the reporting procedure, gives managers one consistent message, gives frontline staff a pocket card that works without signal, and sets up a regular check of volunteer and guest accounts. It fits within the $65k budget, takes about five minutes of team time in a month, and works around the service-system migration.

After 12 months, we'd expect more frontline staff to report phishing (31% to 45%) and to feel comfortable admitting mistakes (55% to 65%). No volunteer or guest accounts should stay active more than 14 days after someone leaves. Reports will probably go up in the first year, which means problems are being caught earlier.

2. Organisational discovery and evidence

Evidence source	What it tells us	Limitations / uncertainty	How it influenced our analysis
Organisational Briefing (A–D)	118 staff and 236 volunteers. Hybrid and outreach work. Cyber ownership is split across the COO, Quality / Risk and the Digital Systems Lead. 65k uplift budget and 2.0 FTE.	Describes the organisation, but doesn't explain why people behave the way they do.	Set the limits for what we could realistically propose.
Staff Pulse Survey (E1)	68% know where to report, but only 39% reported the last suspicious item through a formal channel. Only 47% can find guidance quickly.	Self-report 78% response rate. People may answer in a way thats untruthful but makes them look good.	Showed a gap between what people say and what they do.
Survey by group (E2)	Frontline lowest on workflow fit (40%) and comfort reporting mistakes (55%). Other groups scored 50–83% and 63–83%.	Groups are different sizes (6 to 40 people).	Points to Frontline as a distinct risk population, not "staff" generally

Volunteer Survey (E3)	Only 51% got guidance in the last 12 months. Only 49% know if their access is current. 46% prefer a short demonstration.	33% response rate. Skews towards regular volunteers.	Showed volunteer onboarding and offboarding isn't well covered.
Learning/Phishing Snapshot (E4)	89% completed training overall, but Frontline only 83.3%. Frontline had the highest click rate of 13% and the lowest report rate of 31%	One exercise only. Finishing training doesn't mean people can do it perfectly.	Confirmed the frontline gap in a second source, separate from the survey.
Access Review (E5)	3 of 12 volunteer accounts were active more than 14 days after the person had left. 3 of 40 employee accounts didn't match the person's role.	A 60-account sample, not a full audit.	Showed the August 2026 account was part of a pattern, not a one-off.
Helpdesk Tickets (E6)	95 tickets in 12 months. Suspicious email (29) is the biggest category. Access requests (18) take a median of 8.4 hours, among the slowest to resolve.	Only shows what was formally reported.	Supports our focus on reporting problems and on accounts being switched off.
Site Indicators (E7)	Regional East and Outreach have more connectivity and helpdesk issues than their headcount would suggest.	Could be problems, different reporting habits or how the sites are actually managed.	Suggested outreach and mobile work is part of the cause, not only the Frontline role.
Focus Groups (F1)	Managers can give different advice. Connections drop out mid-visit. Volunteers prefer short live demos over online modules (E3: 46%).	Small, voluntary groups. Can't show how common something is.	Helped explain why the Frontline gap might actually exist.
Leadership Interviews (F2)	CEO wants 2-3 real-life risks, not a wish list. The COO needs the plan timed around the service system migration. The P&C Manager says finishing training doesn't show capability.	Each view has different perspectives, which could cause possible blind spots.	Set what a believable plan needs to include and how it should be timed.
Board Risk Dashboard (G2)	Risk rating HIGH, with no confirmed major incidents occurring. The Board asked whether the current numbers prove risk is going down.	By their own admission, there's no stable behavioural baseline yet.	This is why we measure behaviour and risk, not only training completion (see section 8)

Evidence points strongly towards Frontline staff as a separate high risk group. This is confirmed in three independent places: the staff survey (lowest workflow fit and comfort reporting mistakes that had been made), the phishing exercise (highest click rate, lowest report rate) and the focus groups (connection drop outs, mixed manager advice). Access gaps show a similar pattern across three sources: The August 2026 near miss (a volunteer account was still active 19 days after they had exited the company), the access review (E5), and the volunteer survey (E3), where only 49% of people knew whether their access was current. The clearest tension is between what people say and what they actually do: 68% of staff say they know where to report a suspicious event, but only 39% reported through a formal channel last time.

Stakeholder inquiry

The Stakeholder Interview Simulator was removed from Assessment 3 by the subject coordinator, A/Prof Leanne Ngo, due to access restrictions.

3. Human Risk Assessment

Behaviour / condition	Threat or exposure	Potential organisational / client impact	Evidence	Uncertainty / alternative explanation
Frontline workarounds on outreach visits	Data handled outside approved processes; staff more likely to fall for phishing.	Client information could be exposed (C), records could end up wrong or incomplete (I), and visits could be disrupted (A).	E2 workflow fit 40% vs 66%; E4 click rate 13%; F1 connectivity drop-outs; E7 high issue rates at Regional East and Outreach.	Focus groups were small and voluntary. The E7 site pattern could come from how those sites are managed rather than from more workarounds
Inconsistent manager guidance	Staff aren't sure what counts, so suspicious emails or activity go unreported	Problems are picked up later and have more time to spread (C, A)	F1; E1 68% know how to report, but 39% did last time	We have no survey data on manager consistency, only what focus groups said
Low comfort admitting mistakes	Someone who clicks a bad link may say nothing, leaving the account	An attacker could keep access to client data for longer (C, I)	E2 55% vs 74%; E4 frontline report rate 31%	Self-reported. Some staff may not realise they made a mistake.

	compromised			
Safeguarding-focused reporting procedure	Cyber incidents aren’t recognised as reportable or go to the wrong place.	Leadership can't see what is happening, so the Board can’t tell whether risk is going down.	E1 only 47% can find guidance quickly; E6 suspicious email is the biggest ticket category (29); G2 Board query on metrics; Incident Reporting Procedure (2024)	Helpdesk tickets only capture formal reports, so we don't know the real number of incidents.
No clear owner for volunteer/guest offboarding	Accounts stay active after people leave and could be used by them or by an attacker.	Unauthorised access to client records (C, I), plus privacy and reputational damage.	Aug 2026 near-miss (account active 19 days after exit); E5 3/12 volunteer and 2/8 guest accounts; E3 only 49% of volunteers know if their access is current; E6 access requests take a median 8.4 hours	Based on a 60-account sample, not a full audit.

Employee access not updated on role change	People keep access they no longer need.	If an account is compromised, more systems and data are exposed (C, I).	E5: 3 of 40 employee accounts misaligned to role.	Small numbers; some could be role changes still being processed.

We ranked frontline staff first because it's the only finding backed by four separate sources, and it covers the largest client-facing group. The reporting gap came second. It affects how quickly any incident is picked up across all staff, not just one group, and the Board has already asked whether its metrics show improvement. Hand to find guidance is folded in here as one of the causes. Volunteer and guest access came third. It has the strongest hard evidence, a real near-miss confirmed by an account check rather than a survey, but it sits below P2 because it affects a narrower group. Volunteers not receiving guidance is covered here through the live demo, and employee access not matching role is deferred to the same review cycle. We as a group rejected that frontline training completion gap, because the gap is small and completion doesn't show capability, which the P&C manager also pointed out.

4. Priority human-related cybersecurity risks

Priority	Why this matters now	Evidence supporting priority	Trade-offs / constraints	Why prioritised over other issues
Priority 1 - Frontline staff as a distinct high-risk group	Frontline is the biggest group, about 54 people, and they deal with the clients directly. They score worst on almost every measure we have.	It shows up in 4 different sources: ● Only 40% say security fits their work (66% for other groups) ● Only 55% feel okay reporting a mistake (74% for others ● Highest phishing click rate(13%) and lowest report rate(31%) ● Focus group mentioned workarounds and managers giving different advice.	Only have a 65k budget to work with. Leadership doesn't want to take more than 15 mins a month of staff time.	This is the one finding that keeps showing up in every source we checked, so it's hard to argue it isn't real.
Priority 2 - People know what to do but don't do it	68% say they know how to report something suspicious, but only 39% actually did it last time. People aren't missing the knowledge; they just aren't acting on it.	It comes directly from the staff survey (E1). Only 47% can find the guidance quickly, and that was the lowest-scoring item. The July 2026 MFA near-miss, where the prompts were reported the next morning.	The Incident Reporting Procedure (2024) was mostly written for safeguarding, not cyber. So the process may need to be fixed.	The board themselves flagged this risk; they asked whether the numbers they're tracking actually prove anything is getting better.

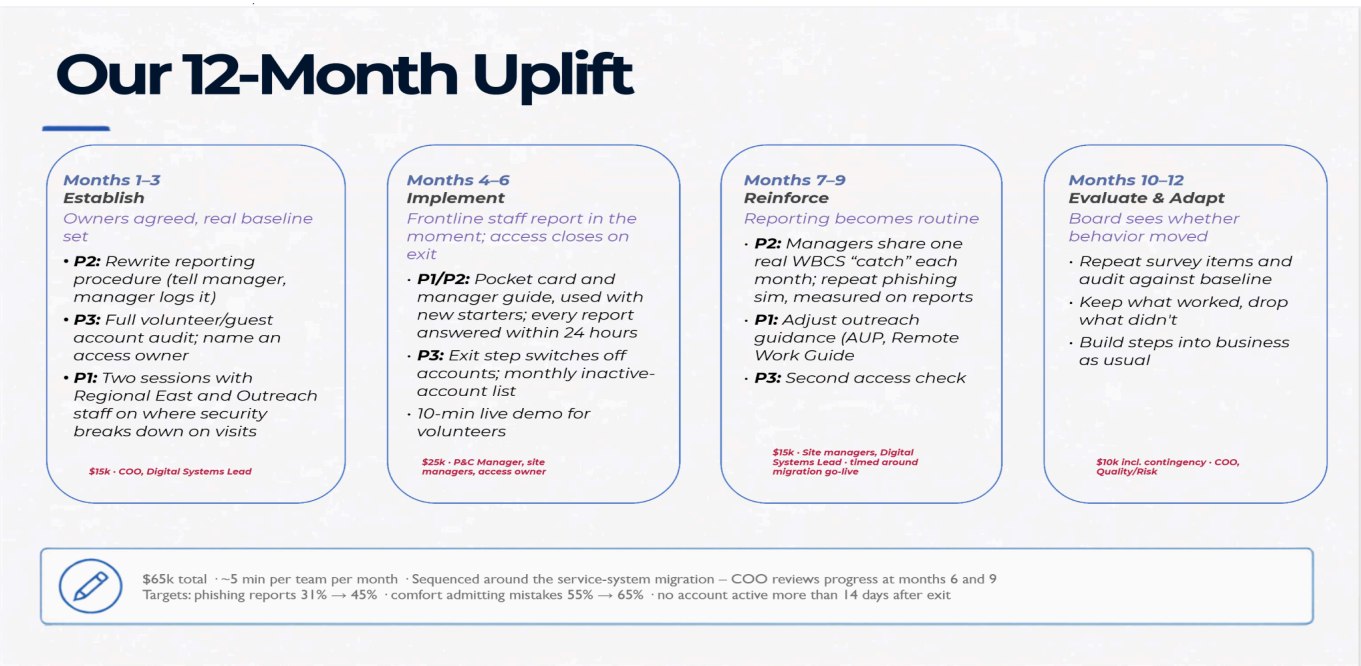
Priority 3 - Old accounts don't get switched off properly	Accounts staying active after people leave is a standing risk that just sits there until someone notices it or an attacker takes advantage	• In August 2026, a volunteer's account was still active 19 days after they had left. • A check of 60 accounts found problems with 3 out of 12 volunteer accounts and 2 of 8 guest and partner accounts • Only 49% of volunteers know if their access is current.	VolunteerLoop is an old system, and it's actually unclear who's responsible for taking care of it.	Based on an actual account audit WattleBridge ran, not actually a survey, a real records check found genuine issues, which is stronger evidence than self-reported uncertainty

5. Proposed 12-month cyber culture uplift

Phase	Objective / desired behaviour	Key intervention(s) / control(s)	Owner & audience	Resources/feasibility	Reinforcement & intended outcome
Months 1-3: Establish	Ownership agreed; real baseline known.	P2: Incident reporting procedure reworded so that staff members report the incident to the manager and the manager logs the incident. P3: Complete volunteer and guest account audit; access owner identified. P1: Two sessions with regional East and Outreach staff regarding where security breaches may occur during a visit.	COO sponsors; Digital Systems Lead, BluePeak Audience: executives, managers.	$15k. No routine staff time; independent of migration	Baseline on Board dashboard at month 3.

Months 4-6: Implement	Frontline staff report in the moment; access closes on exit	P1/P2: card and manager guide launched with new starters; every report responded to within 24 hours. P3: exit step causes drop-out; monthly account inactive list; 10-minute live demo for volunteers	P&C Manager, site managers, access owner. Audience: frontline staff, volunteers.	$25k. Five minutes monthly per team.	Managers repeat one message monthly; reports rise. COO reviews progress at month 6.
Months 7-9: Reinforce	Reporting is routine.	P2: Managers jointly identify one WBCS catch each month; the simulation is repeated and evaluated in terms of the number of reports. P1: outreach guidance is modified depending on the result of the session (Kirlappos et al., 2014). P3: a second check is conducted.	Site Managers, Digital Systems Lead. Audience: frontline teams.	$15k. Depends on migration go-live.	COO reviews at month 9; frontline gap narrows
Months 10-12: Evaluate & Adapt	Board sees whether behaviour moved.	All: survey items and audit repeated against baseline; what worked, drop the rest; steps written into business as usual and BluePeak's scope	COO Quality/Risk. Audience: Board	$10k including contingency.	Dashboard reports behaviour; next priorities set.

Alternative rejected: an organisation-wide refresher module, because completion is already 89%. Residual risk: connectivity workarounds continue until the migration lands, and VolunteerLoop's ownership may stay undecided.

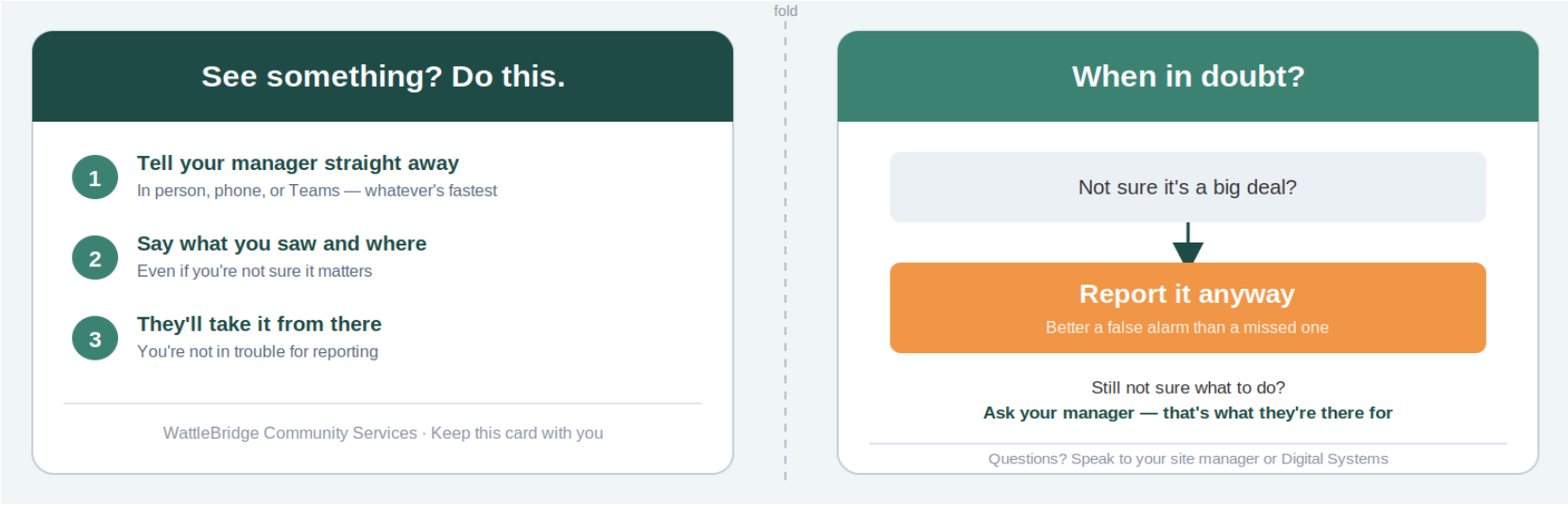


6. Behaviour change in practice: prototype artefacts

Prototype 1 - Frontline staff

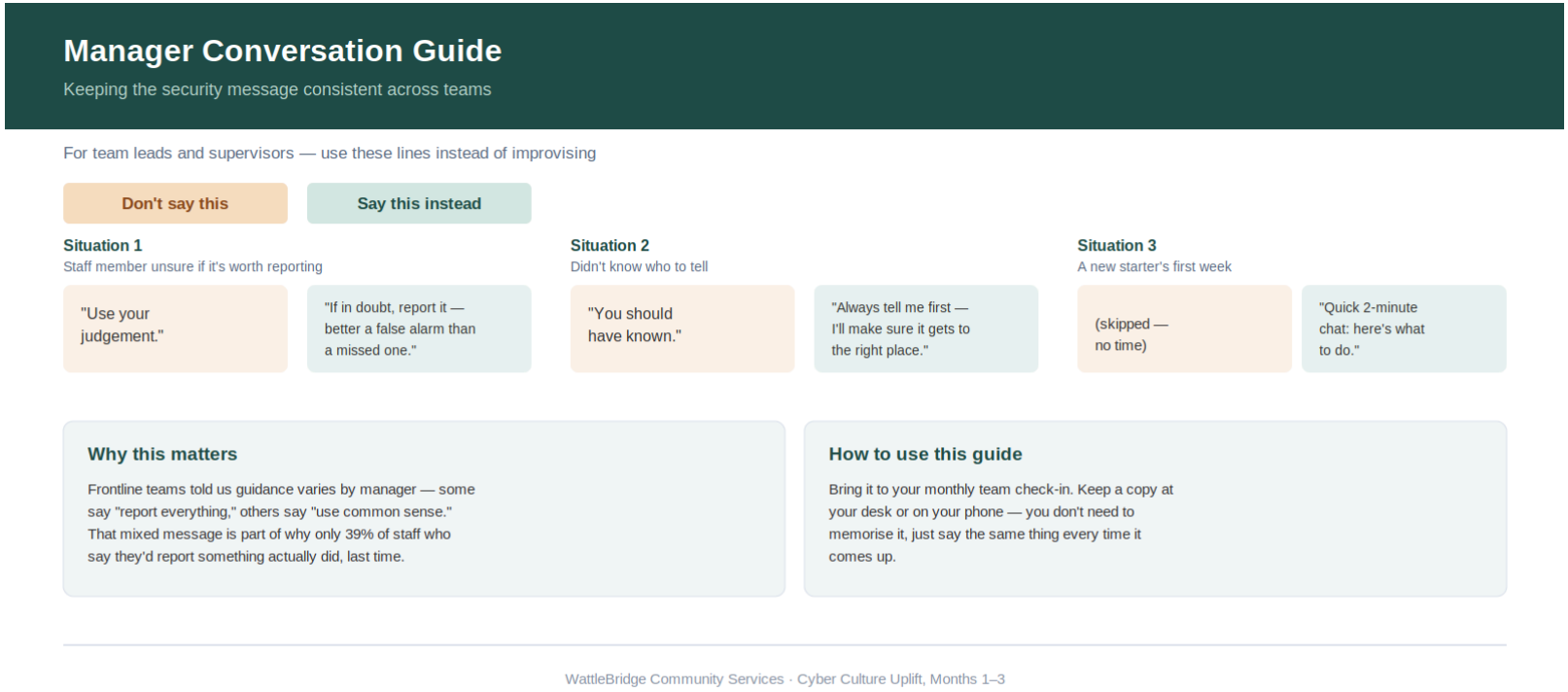
Audience	Desired behaviour	Evidence/problem addressed	Why this design/channel	How it will be reinforced

Frontline staff, the group that scores lowest on workflow fit and comfort reporting mistakes.	Actually report something suspicious through the formal channels, in the moment, instead of ignoring it or working around it	The gap between knowing and doing. 68% say they know how to report, but only 39% reported through a formal channel the last time they got something suspicious (E1 ; only 47% could find the guidance quickly (E1)	A pocket card they could keep on them or have hanging up on their whiteboard, not another online module they will skim over and forget. ● It fits the 15 min/month limit rule ● It works when they don't have access to their computers or the internet. ● Frontline said they'd report more with one obvious number and no fear of wasting time (F3) Short, simple steps matter because too many security demands lead to fatigue and workarounds (Stanton et al., 2016).	● Managers bring it up in team meetings. ● It's handed out at onboarding



Prototype 2 - Frontline team managers

Audience	Desired behaviour	Evidence / problem addressed	Why this design / channel	How it will be reinforced
Frontline team managers/supervisors, not the staff themselves	Give their team the same security message every time. Right now it's mixed: some say "report everything", others say "use your common sense"	Focus groups showed guidance from managers isn't consistent (F1)	A short conversation guide rather than more training; managers already talk to their staff regularly, so this just gives them the right words to use, without needing to turn them into security experts.	• Used in the monthly team check-ins that already do happen. • A one-pager that they can open on their phone or laptop mid-conversation.



7. Governance, controls and framework alignment

Recommendation / control	Owner / accountable role	Policy / process implication	Framework / guidance alignment	Why fit-for-purpose for WattleBridge
Update the Incident Reporting Procedure to actually cover cyber events, not just safeguarding, and pair it with the frontline card and manager guide	Digital Systems Lead writes the update. COO signs it off.	The Incident Reporting Procedure (2024) mostly gives safeguarding examples and mentions cyber near misses once. It needs cyber examples and a clear escalation path. It should ask for the same basics a formal ACSC report asks for: what type of incident it looks like, when it was noticed, whether it is still happening, and what it may affect (Australian Cyber Security Centre [ACSC], n.d.).	NIST CSF: Respond (clear ways to report and communicate) (National Institute of Standards and Technology [NIST], 2024).	People already know how to report but often don't. Fixing the process and prompting the behaviour will do more than more awareness content.
Give Frontline staff their own short security	P&C Manager owns the content.	The Acceptable Use Policy (2023) and the	NIST CSF: Protect (awareness and	The current policies were written before outreach work was

induction, instead of the same generic training everyone gets	Site managers deliver it	Remote & Flexible Work Guide (2021) don't cover mobile or outreach work. Both need updating to match how Frontline actually works.	training) (NIST, 2024).	common, so this fixes something that is actually out of date. It doesn't pile more training on top.
Run a scheduled access review of volunteer, guest and partner accounts, with a fixed checklist for when people leave.	Digital Systems Lead does the technical side. Whoever manages the volunteers triggers the exit step.	Information Security Policy (2022) only says "all staff" and "IT" are responsible. It needs to name who switches access off.	NIST CSF: Protect (who has access to what) (NIST, 2024).	There's a real near miss, and the pattern shows up in three sources, so it isn't a guess. A scheduled check is realistic with 2.0 FTE, unlike rebuilding the system.

Use frameworks to support and justify decisions, not to replace your analysis.

8. Measurement and evaluation

Measure	Type	Baseline / starting point	How measured	Review timing / owner	What would trigger adaptation?
Share of frontline teams holding five-minute monthly security conversation	Activity	No baseline as this is new. Counting starts at launch in month 4. Target 80% of teams.	Managers tick a box in their normal team check-in notes	Monthly, P&C Manager	Under 60% for two months in a row. Ask managers why before pushing harder.
Share of frontline staff who report the phishing simulation	Behaviour	31% now (E4). Target 45%	Repeat the simulation and check the report log.	Quarterly, Digital System Lead	No rise by month 9. Ask frontline staff what's getting in the way of the reporting route.
Share of frontline staff comfortable reporting a mistake	Culture	55% now (E2). Target 65%.	Repeat the same survey question at months 6 and 12.	Every six months, P&C Manager	Reports go up, but comfort doesn't. Look at how managers respond when someone reports
Volunteer and guest accounts found dormant or with no owner	Risk	Only a 60-account sample so far (E5): 3 of 12 volunteer and 2 of 8 guest accounts. The month 3 audit sets the real baseline. Target: none left active past 14 days	Quarterly review of all volunteer and guest accounts	Quarterly, Digital Systems Lead reporting to the COO	The same accounts keep turning up. Switch to automatic suspension of inactive accounts.

The completion of training is deliberately omitted as it is currently at 89% and the Board questioned if that demonstrates something. Reports are predicted to increase in year one as staff reporting is an early form of detection (Lain et al., 2022). The COO will review outcomes at months 6 and 9 and revise the plan (NIST, 2024)

9. Closing recommendation

We recommend WattleBridge spend the next 12 months fixing the conditions behind its three main risks rather than running more training. Executives should remember three things -

1. Staff know what to do. The gap is in acting on it, so making reports easier and safer matters more than more awareness content.
2. Risk is concentrated in frontline work and in volunteer and guest accounts, so that's where the $65k should go.
3. Success should be judged on behaviour and risk outcomes, not completion rates, and reports should rise in the first year as problems get caught earlier.

During the live meeting, we'd like to cover:

- A decision on who owns volunteer offboarding and VolunteerLoop.
- Clarification on the migration timeline, so months 7-9 can be scheduled around it.
- Further investigation on how many staff actually came across something suspicious, which affects how much weight the 39% reporting figure can carry.

10. Evidence and references

Australian Cyber Security Centre. (n.d.). Report a cyber security incident. Australian Signals Directorate. https://www.cyber.gov.au/report-and-recover/report/report-a-cyber-security-incident

Kirlappos, I., Parkin, S., & Sasse, M. A. (2014). Learning from "shadow security": Why understanding non-compliance provides the basis for effective security. In Workshop on Usable Security. Internet Society. https://doi.org/10.14722/usec.2014.23007

Lain, D., Kostiainen, K., & Capkun, S. (2022). Phishing in organisations: Findings from a large-scale and long-term study. In 2022 IEEE Symposium on Security and Privacy (SP) (pp. 842–859). IEEE. https://doi.org/10.1109/SP46214.2022.9833766

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Stanton, B., Theofanos, M. F., Prettyman, S. S., & Furman, S. (2016). Security fatigue. IT Professional, 18(5), 26–32. https://doi.org/10.1109/MITP.2016.84

Privacy (SP), 842–859. https://doi.org/10.1109/sp46214.2022.9833766

Executive Briefing

Advisory Team Name

Cybersecurity Advisory Team — A3 Group 38

WattleBridge Community Services

WattleBridge Community Services

Briefing Purpose

To brief the WattleBridge Executive Leadership Team on our priority human-related cybersecurity risks and proposed 12-month cyber culture uplift.

WattleBridge
Community Services

What We Discovered

1 Insight 1

Frontline staff are a distinct risk population, lowest on workflow fit, mistake-reporting comfort, and phishing-sim report rate, confirmed across four independent sources.

2 Insight 2

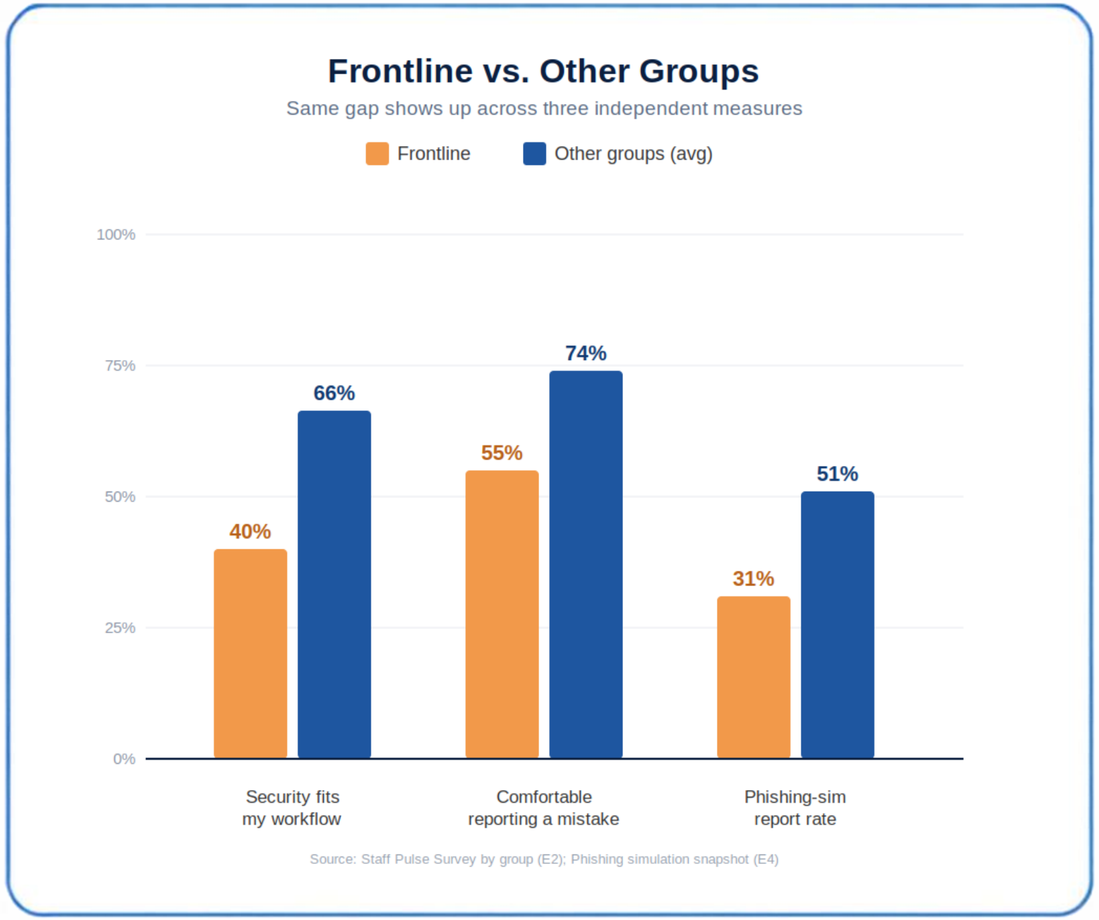
Staff know what to do more than they do it — 68% say they know where to report a suspicious event, but only 39% actually did last time.

3 Insight 3

Access lifecycle gaps recur, dormant volunteer accounts, unclear guest/partner ownership, and a confirmed near-miss all point the same way.

4 Insight 4

Zero confirmed major incidents in 12 months but 6 recorded near-misses suggest controls are catching things, not that risk is absent.



The Human Risk Picture



Behaviours and Conditions

- Frontline workarounds on outreach visits
- Mixed manager advice, and low comfort admitting mistakes
- No clear owner for switching off old accounts



Threat/Exposure

- Frontline workarounds on outreach visits
- Mixed manager advice, and low comfort admitting mistakes
- No clear owner for switching off old accounts



Organisational/ Client Impact

- Client information exposed, records wrong, visits disrupted
- Problems spread, and the Board can't see if risk is falling
- Unauthorised access to client records, plus privacy and reputation damage

Our Priorities

1

Priority 1

Frontline staff are the highest-risk group

Evidence

Weakest across 4 independent sources - workflow fit, reporting comfort, phishing-sim results, focus groups

Why it matters

Biggest group (40 people), most client-facing, the risk that shows up everywhere we looked

2

Priority 2

Staff know what to do, but don't do it

Evidence

68% know how to actually report but only 39% actually did last time

Why it matters

It's a behaviour gap, not an awareness gap, more training won't fix it

3

Priority 3

Old accounts don't get switched off properly

Evidence

Confirmed Aug 2026 near-miss; access review found similar issues across volunteer and guest accounts

Why it matters

A standing risk that sits there until someone notices, or an attacker does

What Is Driving the Risk?

The contributing conditions or influences behind the risk.

Workload
Systems team (2.0 FTE) already at capacity; access requests slowest to resolve (E6)

Time Pressure
Connectivity drops out mid-visit (F1), so the security step competes with the client

Usability
Only 40% of frontline say security fits their workflow (E2); 47% find guidance quickly (E1)

Processes
Reporting procedure (2024) built for safeguarding; no exit step for volunteer/guest accounts (E5)

Role Clarity
Cyber ownership split across COO, Quality/Risk and Digital Systems; no clear owner for VolunteerLoop

Leadership
Managers give inconsistent guidance (F1); Board unsure whether risk is reducing (G2)

Norms
Only 55% of frontline comfortable admitting mistakes (E2); 31% report phishing (E4)

Competing Priorities
Service-system migration underway (F2); ~15 min/month staff time cap



236 volunteers across 5 sites, and only 51% received guidance in the last year (E3). Outreach and Regional East sites have high connectivity and helpdesk issues (E7). The AUP (2023) and Remote & Flexible Work Guide (2021) were written before outreach work was common.

Our 12-Month Uplift

Months 1–3
Establish
Owners agreed, real baseline set

- ***P2:*** *Rewrite reporting procedure (tell manager, manager logs it)*
- ***P3:*** *Full volunteer/guest account audit; name an access owner*
- ***P1:*** *Two sessions with Regional East and Outreach staff on where security breaks down on visits*

$15k · COO, Digital Systems Lead

Months 4–6
Implement
Frontline staff report in the moment; access closes on exit

- ***P1/P2:*** *Pocket card and manager guide, used with new starters; every report answered within 24 hours*
- ***P3:*** *Exit step switches off accounts; monthly inactive-account list*
- *10-min live demo for volunteers*

$25k · P&C Manager, site managers, access owner

Months 7–9
Reinforce
Reporting becomes routine

- ***P2:*** *Managers share one real WBCS "catch" each month; repeat phishing sim, measured on reports*
- ***P1:*** *Adjust outreach guidance (AUP, Remote Work Guide*
- ***P3:*** *Second access check*

$15k · Site managers, Digital Systems Lead · timed around migration go-live

Months 10–12
Evaluate & Adapt
Board sees whether behavior moved

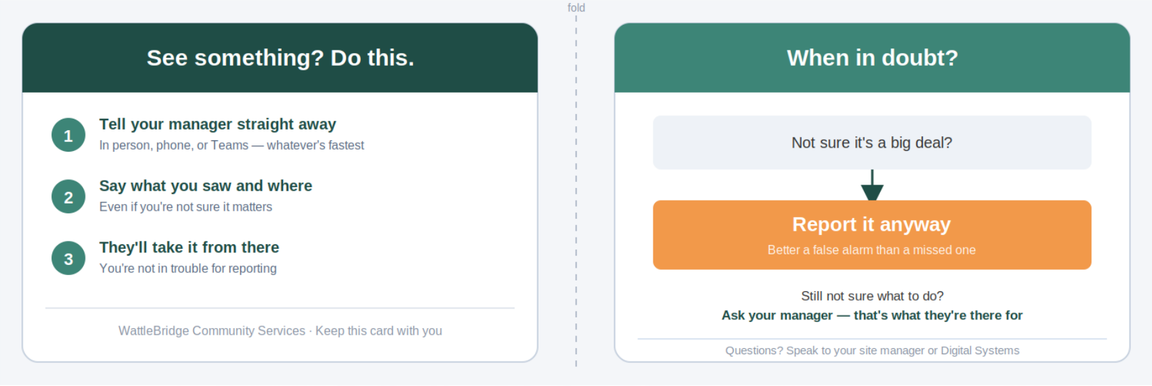
- *Repeat survey items and audit against baseline*
- *Keep what worked, drop what didn't*
- *Build steps into business as usual*

$10k incl. contingency · COO, Quality/Risk

$65k total · ~5 min per team per month · Sequenced around the service-system migration – COO reviews progress at months 6 and 9
Targets: phishing reports 31% → 45% · comfort admitting mistakes 55% → 65% · no account active more than 14 days after exit

Behaviour Change in Practice

Prototype 1 - Frontline Staff



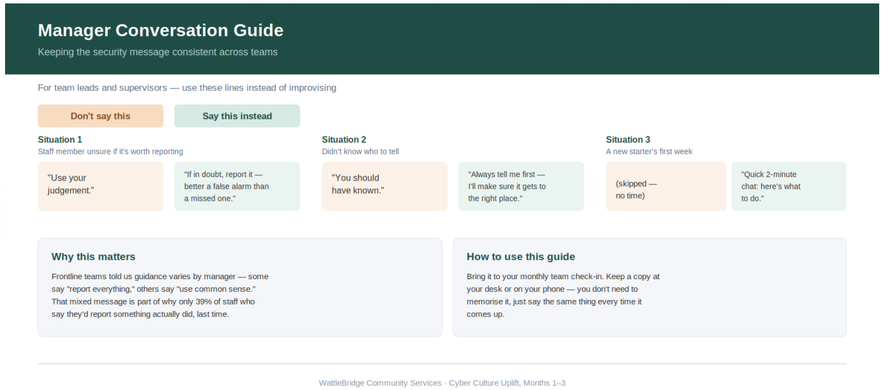
Audience: Frontline Staff

Desired behaviour: Report something suspicious in the moment, through the formal channel

Evidence: 68% know how to report, only 39% did last time (E1)

Reinforced by: Manager huddles, onboarding, QR code to digital version

Prototype 2 - Frontline Managers



Audience: Frontline Managers

Desired behaviour: Give consistent security guidance, not a mix of messages

Evidence: Focus groups showed inconsistent manager guidance (F1)

Reinforced by: Slotted into existing monthly team-lead check-ins

Making It Work at WattleBridge

HOW WE WILL MAKE IT WORK

Governance
Digital Systems Lead and P&C Manager own day-to-day actions; COO signs off on process changes

Ownership
Every recommendation has one named accountable role, not vague "all staff/IT"

Resources
Fits within the existing $65k budget and 2.0 FTE capacity, no new hires are going to be needed

Feasibility
Builds on procedures WattleBridge already has, rather than new ones

HOW IT FITS AND WHAT WE'LL MANAGE

Service delivery
Scheduled reviews and process updates run in the background, without disrupting client services

Framework alignment
NIST CSF - Protect and Respond functions guided which fix targets which problem

Trade-offs
Must sequence around the COO's service migration; VolunteerLoop's ownership is still unresolved

How Will We Know?



INDICATORS

Activity	Behaviour	Culture/Risk Outcome
• *Frontline teams holding the monthly 5 minute security conversation*	• *Frontline staff reporting the phishing simulation*	• *Staff comfortable admitting mistakes: 55% now, target 65%*
• *Target: 80% of teams*	• *31% now, target 45%*	• *No volunteer or guest account active more than 14 days after exit*

Information from the manager's check-in notes, phishing simulation report log, a repeat staff survey and a quarterly access review. Reviewed on a monthly to six-monthly basis, with a COO review at months 6 and 9. Reports should increase in year one, as issues are picked up earlier.

Executive Recommendation

Our Recommendations

1 Make Security fit frontline work

Give frontline staff a pocket card and managers a conversation guide, so everyone hears one consistent message. Aim: frontline phishing reports from 31% to 45%.

2 Make reporting easy and safe

Rewrite the reporting procedure to cover cyber events and answer every report within 24 hours. Aim: comfort admitting mistakes from 55% to 65%.

3 Close access when people leave

Name an access owner, add an exit step and check volunteer and guest accounts every quarter. Aim: no account active more than 14 days after exit.

Immediate Next Steps

- [ ] Rewrite the Incident Reporting Procedure to cover cyber events. Owner: Digital Systems Lead, signed off by the COO. Starts month 1.
- [ ] Audit all volunteer and guest accounts and name an access owner. Owner: Digital Systems Lead. Months 1–3.
- [ ] Run two sessions with Regional East and Outreach staff on where security breaks down during visits. Owner: COO (sponsor). Months 1–3.

Main Message for Leadership

> Most staff already know what to do; the gap is acting on it. We're asking leadership to endorse a $65k, 12-month plan that fixes the conditions behind these risks, and to treat a rise in reports in year one as a sign that problems are being caught earlier.